APPLICATION SECURITY REVIEW

Intake Questionnaire

Acme Inventory API

Submitted Ticket ASR-2026-033, received 2026-08-18

Complete this form to request an application security review. The AppSec team uses it to set the review depth and to schedule testing. Answers below were completed by the requester (shown in blue italics).

A. Request details

A1 Application name and version	*Acme Inventory API 3.2.1*
A2 Business owner / product owner	*Marcus Oyelaran, Warehouse Operations*
A3 Technical lead	*Sofia Alvarez*
A4 Business unit and cost centre	*Supply Chain, cost centre 3305*
A5 Reason for review (new release, major change, annual, audit)	*Annual review and new export endpoint*
A6 Target go-live date	*2026-09-05*

B. Application overview

B1 What does the application do, and who uses it?	*REST API that returns stock levels to warehouse scanners and the ordering system.*
B2 Internet-facing, internal only, or partner access?	*Internal only (warehouse network and ordering system)*
B3 Application tier (business criticality)	*Tier 3 (standard)*
B4 Languages, frameworks and runtime	*Python 3.12, PostgreSQL, Docker on ECS*

C. Data

C1 Most sensitive data processed or stored	*SKU names and stock counts*
C2 Data classification	*Internal*
C3 Regulatory scope (PCI DSS, GDPR, SOX, HIPAA, none)	*None*
C4 Data retention and deletion approach	*Stock history kept 2 years*

D. Architecture and hosting

D1 Hosting platform and regions	*AWS eu-west-1: ECS Fargate, RDS PostgreSQL, S3*
D2 Datastores and encryption at rest	*RDS and S3 encrypted; S3 public access blocked*
D3 Inbound and outbound integrations	*Inbound from scanners and the ordering system; no outbound*
D4 Secrets management	*API key from AWS Secrets Manager via environment*

DEMO DOCUMENT - Acme Corp is fictional and every finding, name and date is invented for a proof of concept.

E. Identity and access

E1 How are users authenticated?	*API key header (X-Api-Key), hashed comparison*
E2 How is authorisation enforced (roles, ownership checks)?	*Single read-only role*
E3 Privileged / admin functions	*None*

F. Delivery pipeline

F1 Source control and branch protection	*GitHub; branch protection, two reviewers, signed commits*
F2 Automated security checks in CI	*Demo pipeline: secrets, SAST, SCA, IaC, container, DAST, SBOM*
F3 Open-source dependency management	*Dependabot with weekly updates*
F4 Previous penetration tests or reviews	*Internal review 2025: no findings above Low*

G. Declaration

G1 Requester	*Sofia Alvarez, Technical Lead*
G2 Date submitted	*2026-08-18*

AppSec triage (completed by reviewer)

Assigned tier	Tier 3 (standard)
Review depth	Light review: pipeline results and design check
Triaged by	AppSec Review Team (demo)
Report ticket	ASR-2026-033